



Sri Lanka Institute of Information Technology

B.Sc. Honours Degree in Information Technology

Final Examination
Year 3, Semester 2 (2023)

IT3070 – Information Assurance & Security

Duration: 2 Hours

November 2023

Instructions to Candidates:

- ◆ This paper has FOUR questions.
- ◆ Answer all questions in the booklet given.
- ◆ This paper is preceded by a 10-minute reading period. The supervisor will indicate when answering may commence.
- ◆ The total mark for the paper is 100.
- ◆ This paper contains SIX pages, including the cover page.
- ◆ Faculty approved calculators are allowed.

Question 1**(25 Marks)**

- a. Read the following case study and answer the questions.

"ExpressLRS, an open-source radio control link commonly used by drones thanks to its low latency and high range, has been found to be easily hijacked. Using only a standard ExpressLRS-compatible transmitter, researchers at NCC group were able to hijack control "of any receiver after first observing traffic from a corresponding transmitter. The problem stems from ExpressLRS' use of a Unique Equipment ID hardcoded into transmitter and receiver pairs that only uses MD5 hashing, long considered insecure. According to NCC Group, weak security makes it possible to extract part of the phrase from listening to signals, while a combination of brute force and analysis can be used to determine the rest. "Once the full Unique Equipment ID is discovered, it is then possible to use an attacker's transmitter to control the craft containing the receiver with no knowledge of the binding phrase," NCC Group said. If a drone in flight were hijacked in such a manner, it's likely to cause a crash, researchers wrote."

- i. Identify the Asset, Vulnerability and the Risk in the case study given.

(6 Marks)

- ii. Suggest a countermeasure 'ExpressLRS' can implement to prevent this type of an attack.

(3 Marks)

- b. The three fundamental bases of information security are represented in the C.I.A triad. Identify the highest priority security C.I.A requirement associated with each given scenario.

- i. You are responsible for the security of an e-commerce website that sells products online. Ensuring that the website remains operational even during peak shopping seasons is crucial to prevent revenue loss due to downtime.

- ii. You are the security analyst for a healthcare organization that stores sensitive patient records. The organization is planning to implement a new electronic health record system and your primary concern is ensuring the protection of patient information from unauthorized access or disclosure.

- iii. You oversee cybersecurity for a government agency that handles classified national security information. Any unauthorized access or exposure of classified data could pose a significant threat to national security.

- iv. You work for a financial institution handling online banking transactions. It is essential to ensure that financial data, such as account balances and transaction details, remain accurate and unaltered during data transmission and storage.

(8 Marks)

c. Map the given attack scenarios to correct categories. Answer the question using the given table template.

- i. Alice works as a system administrator for a financial institution. She secretly installs a packet sniffer on the network infrastructure within the organization's data center. This packet sniffer allows her to monitor network traffic passing through the restricted servers.
- ii. Alex is in a coffee shop. Alex identifies a vulnerable Wi-Fi network used by employees within the next-door office building. This Wi-Fi network uses outdated encryption and security measures, making it susceptible to unauthorized access. Alex manages to get into the Wi-Fi Access point, and he modifies its setting including the Wi-Fi password.
- iii. Anna is a receptionist working for a healthcare organization. She is planning to resign from the company next month. She uses a USB stick to copy confidential patient data.
- iv. A foreign government security agency has installed a spyware application into the mobile phones of diplomats in a neighboring country.

Scenario	Active / Passive	Insider / Outsider
i		
ii		
iii		
iv		

(8 Marks)

Question 2

(25 Marks)

a. Information security controls can be categorized as given below.

Based on the Type of Control: Technical, Physical, Administrative

Based on the Objective of Control: Preventive, Detective, Corrective, Deterrent

Map the given security controls to correct control categorization. Answer the question using the given table template.

- i. Intrusion Detection System (IDS) that monitors network traffic and generates alerts when suspicious or unauthorized activities are identified by the system.
- ii. Conducting a security audit & review of access logs to identify security policy violations.
- iii. A printed warning sign 'Authorized Personnel Only' and a metal barrier at the entrance to a protected server room.
- iv. Automated patching software that applies security updates and fixes software vulnerabilities when identified.

Control	Type of Control	Objective of Control
i		
ii		
iii		
Iv		

(8 Marks)

- b. 'Quantitative Risk Analysis' attempts to assign independent monetary values to system components, therefore offers direct risk cost projection. The following information is extracted from a risk evaluation done by a small enterprise.

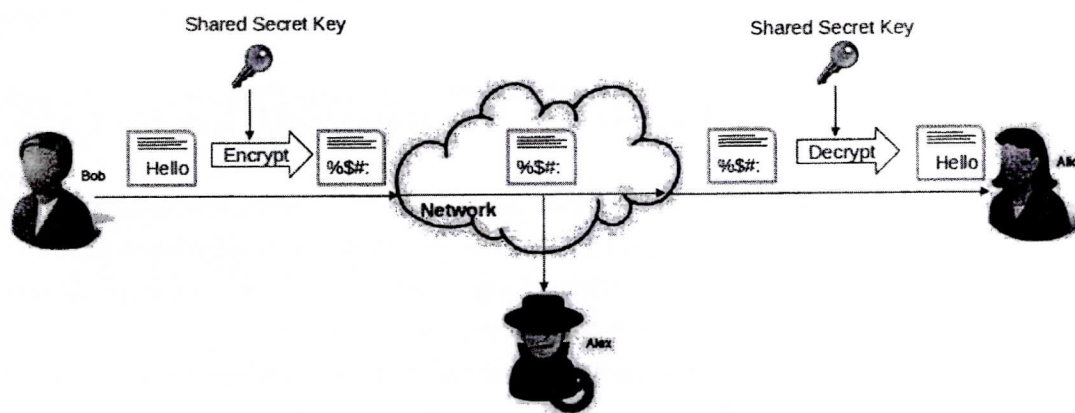
Health Guard (Pvt) Ltd. is a regional hospital that provides a complete range of the latest diagnostic and curative facilities in every aspect of medicine. An initial evaluation was done to identify critical IT assets of the organization along with their values.

E-Channeling Web Server is valued at Rs. 650,000/=. It has been identified that this webserver is vulnerable to a major ransomware attack. An initial data collection has indicated that the server has an exposure factor of 35% for this threat and the ransomware attack is likely to happen once every two years.

- i. Calculate the Single Loss Expectancy (SLE) for the above incident.
(3 Marks)
 - ii. Calculate the Annual Loss Expectancy (ALE) for the above incident.
(3 Marks)
- c. Read the case study, and answer the questions given below.
- "Director of patient billing and collection stated that the Patient Billing and Collection Database (PBCD) is responsible for keeping accurate billing records of the patients. It is essential for negotiating and collecting compensation from insurance organizations. Challenges to bills from insurance organizations can force the hospital to absorb billing differences. Challenges can also significantly delay the time between services being rendered and compensation being received by the hospital. This database contains all the information necessary to bill a patient and his/her insurance company for treatment/services received from the hospital."
- i. Create an OCTAVE critical asset profile for the above case study.
(5 Marks)
 - ii. Assess the most important security requirement for the above asset. Justify your selection.
(3 Marks)
- d. In an alphabet-based substitution cipher, every character of the alphabet is substituted by another character from the alphabet. Compare the brute force attack and frequency analysis attack with respect to breaking a cipher text generated by a substitution cipher.
(3 Marks)

Question 3**(25 Marks)**

- a. Alice and Bob are using the following method illustrated in the diagram to communicate with each other. Answer the questions based on the diagram.



- i. Which cryptographic approach is used in communication between Alice and Bob? (2 Marks)
 - ii. What is the problem Alice and Bob face in the above setup? (2 Marks)
 - iii. Which cryptographic method can be used to overcome the problem mentioned in 'ii'. (2 Marks)
- b. Digital signatures are based on public key cryptography (PKC). PKC algorithms are known to be slower. When digitally signing a large message, we could fragment the long message and digitally sign each piece individually. This is going to be an extremely inefficient approach as it is an extra burden on processing power. Using a diagram propose a faster way to generate a digital signature for this large message. (6 Marks)
- c. You are tasked with creating an Access Control Matrix (ACM) for the Computer Science and Mathematics departments of the ABC University. Using the information provided below, create an Access Control Matrix that represents the access rights of users (U1, U2, U3, U4) to resources (R1, R2, R3, R4). Use "R" to denote read access, "W" for write access, "X" for execute access, and "-" to indicate no access. Assume that users have no access by default.

Users: U1 (Professor), U2 (Graduate Student), U3 (Staff), U4 (Guest)

Resources: R1 (Course Materials), R2 (Research Datasets), R3 (Department Email), R4 (Lab Computers)

Access Control Rules:

1. The Professor has read access to all resources.
2. The Graduate Student has read access to Course Materials and Department Email.
3. The Staff has read access to Course Materials and write access to Research Datasets.
4. The Guest has no access to any resources.

Use the following format to create your ACM.

	R1	R2	R3	R4
U1				
U2				
U3				
U4				

(7 Marks)

- d. Access control is the prevention of unauthorized use of a resource. Propose the most suitable access control policy for the given scenarios below.
- Healthcare system to control access to patient records. Doctors, nurses, and administrative staff might have different jobs with varying levels of access to electronic health records (EHRs).
 - Fileserver implementation for a government top secret research lab where researchers are working on classified projects, and they have different security clearances.
 - An online collaborative document editing software which allows multiple users to collaborate on a single document. The document owner can specify who has read or edit permissions, allowing for easy collaboration while maintaining control over document access.

(6 Marks)

Question 4

(25 Marks)

- Propose two different factors which can be used along with a password to implement a multifactor authentication solution. (4 Marks)
- Mention two different purposes of using 'Salt' values in storage of hashed passwords. (4 Marks)
- Read the case study given below and answer the following questions.

A firewall is configured to protect the subnet 192.168.10.0 /24. Internal hosts may access all external websites (port 80) except 100.23.13.11. All external hosts may access the web server (port 80) on 192.168.10.123 and all other activity is to be blocked.

- Create a firewall table to address the above requirements. (Include the following columns in the table: [Rule Number, Source IP, Source Port, Destination IP, Destination Port, Protocol, Action] (10 Marks)
- Firewall has a management IP address of 192.169.10.1 and to protect the firewall itself, suggest a suitable rule and recommend where to place it in the rule list. (3 Marks)
- Recommend two factors an organization should consider when choosing a third-party business continuity provider. (4 Marks)

(4 Marks)

--End-of-Question-Paper--